1. **Which are the differences between a block and a stream algorithm, their pros and cons and provide an example of each algorithm?**

   Stream algorithm works on variable length data stream, without dividing the whole data in multiple blocks; the block one works on fixed length data (where the length is the block size), so messages longer than one block, will be firstly divided in blocks (if the message length is not a perfect multiple of the block size, it should be padded or CTS mode).

   For stream algorithm:

   Pros: Stream algorithms are faster since they don't need a division in block of the message.

   Cons: They need a synchronization between the parties which share data (good random generator), so they are sensible to de-synchronization attacks.

   For block algorithms:

   Pros: Since they are well-known and used algorithm, they are stronger and so more secure (e.g. AES).

   Cons: They are slower, since they are more complex and they are vulnerable to some kind of attacks if used some unsecure modalities (e.g. ECB).

2. **Two companies want to exchange a message using a TCP connection, they have 12 characters password, how can they communicate?**

   They generate a secure key using the same KDF (*Key Derivation Function*) giving as inputs:

   - **KEY** = **KDF**(P, S, I);

   Where P is the password (or passphrase), S is a salt which means a long and random nonce to make more complex the result and slower the pre-computation and I is the number of iterations the KDF is applied.

   Assuming that data should be sent protected by confidentiality, a symmetric encryption algorithm will be used, such as AES in CBC mode. Let C be the encrypted file:

   C = E-AES-128-CBC(KEY, M, IV);

   Where KEY is the one computed before, M is the message sent and IV is an initialization vector and must be a nonce.

   If data authentication and integrity are needed, a MAC (*Message Authentication* Code) should be provided, calculated for instance using HMAC:

   MAC = HMAC-SHA-256(KEY, C || IV);

   At this point the message exchanged is C||IV||MAC.

   These steps are performed assuming that the algorithms have been previously agreed.

3. **Differences between TLS Client Authentication and HTML form authN, pros and cons.**

   The TLS Client Authentication is performed by the client during the handshake protocol in which it authenticates itself providing his X.509 certificate and answering to an explicit asymmetric challenge, based on previous exchanged messages, using his private key.

   The HTML form Authentication is based on an HTML form in which inserting username and password (which can be a re-usable one or an OTP).

   Pros of the first kind of authentication are:

   - The TLS authentication is a strong authentication since it is based on an asymmetric challenge-response schema;
   - It reduces the attack surface because it is an authentication performed earlier;
   - No secrets are stored on the server;
   - There are automatic (or semi-automatic) mechanisms which map the subject of the public key certificate to an identity at application level.

   Cons:

   - The user requires a X.509 certificate and he should know how to use it and his private key;
   - The server needs to verify that certificate (e.g. trusted Root CA).
   - It is slow, since it uses asymmetric cryptography.

   HTML form based has as pros the cons of TLS and viceversa.

4. **Window of exposure, the impact of the security management and how it can be reduced.**

   The window of exposure is the time between the discover of a vulnerability and the installing of a patch on a specific system for that specific vulnerability. It is made up by some phases:

   - **Discovery:** the time during which a vulnerability is discovered and starting to be exploited;
   - **Publication:** the time in which the vulnerability is publicly known;
   - **Protection:** the time a patch is provided, installed and publicly known.

   The impact of security management is the fact that it must continuously monitor if there are any new vulnerabilities which affects the system, because otherwise we think that we are secure but we are not.

   A way to reduce the woe, before the installing of the patch, is to update the defensive tools like firewall, ids or ips in order to detect if the vulnerability is used against the system. Then, as soon as the patch is available, it should be installed.

5. **Describe the Dual-Homed Gateway, Pros and cons.**

   This architecture is made up by: a packet filter which communicates with the untrusted network and with a dual-homed gateway (since it has two network cards) on which runs an application gateway; this gateway is linked to the internal networks.

This kind of architecture provides an high level security since all the packets are checked twice (at level 3 and level 5); the internal network can be hided without using a NAT and there is the break of the client-server architecture, moreover a single point of failure is avoided.

At the same time this solution is inflexible because all the packets are checked twice even if they don't need both checks and the gateway can be a bottleneck since it can bring to a large work overhead (the packet filter sends more packets than how the gateway can manages); in the end breaking client-server model, the application gateway can be the target of attacks.

6. **Explain the concept "Security is a process, not a product" of Bruce Schneier and make a concrete example of it.**

   Products provide some protection, but the only way to effectively do business in an unsecure world is to put processes in place that recognize the inherent insecurity in the products. The trick is to reduce the risk of exposure regardless of products or patches. A concrete example of this could be the use of a firewall and IDS (Intrusion Detection System), even if the firewall would be wrongly configured or some bugs, the IDS is able to detect possible malicious traffic undetected by firewall.

7. **Explain the CBC mode and the CTR mode.**

   CBC is an application mode for symmetric encryption algorithms, the block ones. Let be P the plaintext which needs to be encrypted, where $|P| = N*B$, N is a positive integer, while B the block size specified by the encryption algorithm used; P is divided in blocks: $P_1, P_2, \ldots, P_N$ where $|P_i| = B$. Then: $C_i = enc(K, P_i \oplus C_{i-1})$, according which $C_0 = IV$ that is a nonce and K is a shared Key between sender and receiver; the cyphertext $C = C_1||C_2|| \ldots ||C_N$. The receiver which has to decrypt C will perform $P_i = dec(K, C_i) \oplus C_{i-1}$ and then get $P = P_1||P_2||\ldots||P_N$.

   CTR is still an application mode but it is used under the hypothesis $|P| < B$. In this case C = P⊕LMG(enc(key, nonce&Counter)). Firstly, a nonce and a counter are combined in order to get a register whose size is B, then it is encrypted with the key shared and the leftmost group (leftmost part long as the plaintext) of the block is xored with the plaintext. The receiver will perform P = C⊕LMG(enc(key, nonce&Counter)). Note that sender and receiver must be synchronized on the same nonce and counter.

   Pros of CBC are: it is not vulnerable to known-plaintext attacks and block swapping.

   Cons of CBC: it is slow, it can not be parallelized, it needs an IV, there is error propagation (in case of an error in one block) and since it is a sequential algorithm it is not possible to encrypt a random P_i without encrypting previous blocks.

   Pros of CTR are: it is not vulnerable to known-plaintext as well, there is direct access since it is not a sequential algorithm, it can be parallelized, so it is fast and there is no error propagation.

   Cons of CTR are: there is needing of a nonce and a counter and it is vulnerable to desynchronization attacks (e.g. cancellation attacks).

8. **Explain symmetric challenge-response mechanism.**

   The server will send a challenge to the client, this challenge is a nonce, the client will compute an hash on the nonce and the key and reply to the server. At this point, the server which stores the key in clear, will compute the same hash on the nonce and the key stored, if the result is the same of the one received then the client will be authenticated.

   Pros of this authentication mechanism are: it is fast and simple since it is based on an hash function and a shared key, it is not vulnerable to sniffing attacks since it uses hashes which are not invertible and it is not vulnerable to replay attacks because a nonce is used.

   The con is: the server needs to store the secret in clear.

9. **Pros and Cons of TLS Client Authentication and if used, which are the tips to adopt on client and server?**

   Pros and Cons see 12-02-2020 (n.3).

   A possible tip for the client is that it needs to protect his private key in some way, for instance by using FIDO or a Smart Card; moreover, the client needs to verify the status of the Public Key Certificate of the server therefore CRL or OCSP must be enabled, the same thing must be done on the server and additionally, server must know which are the trusted root CA. The server have also to enable HSTS with preload (since all the interactions between the client and the server will be only through a TLS channel) and also HPKP to pin his public key. The server should be equipped with HSM since many asymmetric cryptographic operations will be performed.

10. **How does FIDO work and which are its advantages?**

    It is a client-server authentication system based on the use of asymmetric cryptography. When a user wants to register to a server, with FIDO, he will create a specific pair of asymmetric keys and will give the public one to the server and keep the private one. When the user wants to perform the login an asymmetric challenge-response protocol will be run by the server towards the user based on these asymmetric keys.

    The main advantages are:

    - Since asymmetric cryptography is used the authentication is strong;
    - There is no link-ability since the user will create different asymmetric keys every time he register to a different server;
    - The private key can be also used to digitally sign some transactions;
    - No X.509 certificates are used;
    - No secret is stored on the server;
    - The private key can be protected locally with biometric system;
    - It is possible to generate as many keys as want because private key is computed when needed and not kept on the client, based on an internal secret and on the server identity.

11. **Imagine to be the security manager of an MSA (Message Security Agent), you want to accept only the mails sent by valid users.**

Since the MSA has to accept the email sent by only valid users it cannot be configured as an open mail relay, so the server must require client authentication. The client can authenticate himself using the AUTH command of SMTP with the plain or login method but since these methods require that the user sends his password just encoded in BASE64 these credentials have to be protected by a secure channel. Server and Client can negotiate a TLS channel using the STARTTLS command (with data confidentiality enabled). Pros of this solution are: only authenticated users can send emails, public key certificate is not needed so users can easily authenticate and provides protection against sniffing attacks. Cons, instead, are: the password can be easily guessed, it is possible online password enumeration and the server must store passwords (it can store the hash of the salted password, to avoid dictionary attacks), the attack surface is bigger than the one of client authentication during TLS handshake protocol.

12. List TLS security properties and tell if they are optional or not.

- Server Authentication, compulsory;
- Client Authentication, optional;
- Data Authentication, compulsory;
- Data Integrity, compulsory;
- Data Confidentiality, optional;
- Protection against replay attacks and packet filtering, compulsory;

13. Differences between Intrusion Detection System and Intrusion Prevention System.

The IDS is an intrusion detection system, it can be network or hosted based and it allows to detect eventual actors which are using unauthorized devices or networks and can be also used to detect if valid users are violating their privileges. After the detection and the raising of an alarm, the management is left to a security manager.

The IPS is, typically, made up by an IDS and dynamic distributed firewall, this means that the intrusion would be detected and then it will react automatically, trying to close attack channels.

Advantage of the IDS is that internal attacks can be discovered: the known ones if the IDS is signature based and unknown ones if it is statistic based.

Disadvantage of the IDS is that the presence of a security manager is needed and that unknown attacks which do not alter relevantly statistics pass undetected.

Advantages of the IPS are the same of IDS and, moreover, that it is automatic and there is no need of a person but at the same time it is a disadvantage since it could stop innocent traffic, wrongly declared as malicious. Another disadvantage is the same of IDS, unknown attacks which do not alter significantly statistics pass undetected.

14. Define the terms vulnerability, threat, and security control, then explain which relations exist among them.

A vulnerability is a weakness of an asset. A threat is a deliberate action or an accidental event which can bring to the loss of a security property exploiting a vulnerability.

The security control is an element placed in the system that protect against one specific threat and it reduces risks to which system is exposed to.

A threat could exploit a vulnerability of an asset but thanks to security control it is possible to gain protection against threats.

15. **A user must decide if to protect a file with a MAC or with a digital signature. For each case, describe the operations to be performed, the security properties obtained, and the relative advantages and disadvantages.**

A MAC typically is calculated through a keyed digest, so using symmetric cryptography. A way to calculate a MAC in a secure way is using HMAC, that is based on the use of a cryptographic hash function like SHA-1. The security properties obtained are authentication and integrity of the file. The main advantage of using a MAC is that it is fast, while the main disadvantages are that using a MAC do not provide non-repudiation and a symmetric key must be distributed among the parties. The computation of a digital signature is based on the use of asymmetric cryptography and it requires that the sender needs to have an asymmetric key pair. To compute it the sender has at the first compute the hash of the file and then encrypt the output (the digest) with his private key. The security property obtained are authentication, integrity and possibly non-repudiation of the file if the private key is associated to a valid public key certificate (e.g. X.509). So the main advantages are that this solution give non-repudiation and there is no need to distribute a symmetric key but the disadvantages are that it is slower, require an X.509 certificate and so the receiver has to have some kind of trust in the CA that issue that certificate (it is required only if non-repudiation is needed).

16. **Explain what is a dictionary attack, under which hypothesis it can be made, and which countermeasures may be taken against it.**

A dictionary attack is an attack based on password or passphrase hashes pre-computation. The attacker, for a certain set of passwords computes the hash and stores it in a Database paired with corresponding password of the hash.
At some point the attacker discovers, for some reasons, the hash of someone's password; he performs just a lookup in his database and check if that hash is present or not, if the answer is positive, then he has discovered the corresponding password, else the password is not in the database.
This kind of attack can be made only under two hypothesis: the attacker should know the hash algorithm that the server used and there should be a leakage of information so that the attacker has got the copy of the password hash value.
Since the critical point in this kind of attack is the fact that the attacker performs a pre-computation, a possible countermeasure could be the use of a salt that is a random, unpredictable and long string of bytes that can be concatenated to the password and then perform the hash. Even the attacker knows the hash algorithm, he can start the computation of passwords only when he discovers also the salt and it will take lots of time, till the computation ends the password could be changed.

17. **Explain what is 802.1X, present its features, and discuss its role in a security architecture.**

802.1x is a L2 architecture for authentication, network access control and key management. Its main role in a security architecture is to not give network access to the

unauthorized people or device inside a LAN. In this architecture there is an access point or a switch that acts as a EtherNAS that requires to the clients, called supplicants, that wants to have network access to authenticate themselves. In a backend network there is an authentication server, typically a Radius server that store the credentials of the valid user and their configuration. The supplicants and the EthernNAS will communicate using EAP and will authenticate themselves using one of the authentication mechanism available in EAP. The EtherNAS and the Radius server will communicate using the Radius protocol. In this architecture the dialogue between the supplicant and the AS is direct, since the EtherNAS will acts just as pass-through device.

VARIANT NEEDS ADVANTAGES AND DISADVANTAGES:

Advantages of this solution are: since we are using a radius server as authentication server, the authentication is centralized and it can work as a proxy so it is possible to authenticate valid users that belong to external domains; since authentication is require at L-2 an attacker cannot access to L-3 so he is stopped earlier; so long as EAP is used as an external authentication mechanism, changings of this mechanism do not implies changings in the EtherNAS.

Disadvantages are: an access point or a switch which work as an etherNAS are required, so there could be the needing to buy specific equipment; users should have devices which support EAP in order to authenticate themselves; RADIUS is not a secure protocol since it is vulnerable to many kind of attacks.

18. Explain what defence-in-depth is, why it is needed and make a concrete example.

Defence-in-depth means, basically, that there should not be one defence line but multiple in cascade, in series. It is needed because if there is one single security control, it could fail so there is the needing to avoid relying on single line of defence. A concrete example of this, could be the use of a firewall and an IDS, the first one blocks malicious traffic but even if some is able to pass, the IDS will detect it.

19. Explain Asymmetric Challenge-Response Authentication.

The client to be authenticated sends his public key certificate to the server; the server will create a challenge by encrypting a nonce with the public key of the client, then he will send it to the client that will decrypt it with his private key and send it back in clear. Finally, the server will check if the response corresponds to the nonce created.
Advantages are: this kind of authentication is the strongest authentication possible, it is immune to sniffing attacks and to replay attacks, since a nonce is used.
Disadvantages are: it is a slow authentication since asymmetric crypto is used, there is the need of a valid public key certificate for the client and the server has to verify it, if the format of the challenge is not previously defined, could bring the user to involuntarily sign a document.

20. Consider some network traffic protected with IPsec (V2) ESP in transport mode and tell which security properties would the traffic have. For each property, tell if it is compulsory or optional, how it would be obtained, and which part of the ip packet it would protect.

The security properties of this traffic could be: data authentication and integrity, data confidentiality and partial protection against replay attacks. Partial protection against replay attacks is compulsory while data authentication and integrity and confidentiality can be optional but at least one of them needs to be chosen (either data authentication and integrity or confidentiality). Data authentication and integrity is obtained by the use of a keyed digest, confidentiality can be obtained by the use of symmetric encryption and the partial protection against replay attacks can be obtained by the use of a sequence number (Message Identifier). The only part of the ip packet that would be protected is the payload, no protection at all for the ip header.

21. HTTP basic authentication, advantages and disadvantages.

In HTTP Basic authentication the server is requesting to the client his username and password encoded in BASE64. Advantages it is simple and supported by all servers. Disadvantages are: the password can be guessed, online password enumeration are possible, server must store password (or its hash), it is vulnerable to sniffing attacks and replay attacks if username and password are not sent on a secure channel.

22. What is a key derivation function, what security problem it solves, which kind of cryptographic function is built upon and which are its parameters and their importance.

A Key Derivation Function is a function which starting from a password (or passphrase) generates a secure key that has the same distribution of 0 and 1.

It addresses the problem of generating secure key starting from some secret known by a user. Usually the KDF is built upon a cryptographic hash function. KDF input parameters are: the passphrase known and provided by the user; a salt which is a random, unpredictable and long string of bits which is used in order to generate different keys using the same passphrase; the number of iterations to make the pre-computation of a dictionary more complex.

23. Explain Stuxnet main features, why consider it as a prototype of a new class of attacks and we can learn.

Stuxnet main features are: it was targeting a specific system which was controlling a reactor and at the same time it was hiding as a driver digitally signed by Microsoft.

It can be considered as a prototype of a new class of attacks since it was the first kind of malware to be used for cyberphysical system.

Most important lessons from this attack are: that only useful services should run on a system that has to perform a work, air gap does not implies security because firewall, anti-malwares and anti-virus should also be installed and updated and a validation list of which software can be installed on a system should be used.

24. Weakness of DHCP and what kind of attacks can be performed.

The weakness are basically two: it is not an authenticated protocol and it is a broadcast protocol. Attacks that can be performed are substantially three: the attacker can perform a logical man in the middle attack in which he provides a valid subnet mask to the victim and becoming his default gateway; the second attack is a DoS attack based on the fact that a misconfiguration is provided so the victim cannot access to the network; the third one is

providing the address of a fake default nameserver with the aim of give a bad address translation.

25. Describe and provide a concrete example of Least-Privilege and Need-To-Know.

Least-privilege means that to every element in a system must be assigned the minimum amount of privileges needed to perform its tasks. A concrete example is: if there is and admin account and a user one, to just perform normal operations (e.g. reading emails) the second one should be used, to avoid that an attacker could get root privileges.

Need-To-Know means that every element in a system must access only to the data needed to perform its tasks. An example of this property can be seen in Amazon shipping cycle, where a shipping employee should not have access to payment details.

26. Explain OCSP and CRL.

CRL is the certificate revocation list which provides all the certificates that have been revoked by a certain CA and this list is digitally signed by it. Advantage of this verification of a certificate is that, since there is an indication of when this list has been created, it is possible to verify the status of a certificate at any time, even in the past. Disadvantage of this method is: the CRL is a long file that needs to be downloaded even to check just one certificate.
OCSP stands for Online Certificate Status Protocol, it is a protocol that allows to check the current status of a certificate. Advantage is that the answer is fast and small instead of CRL. Disadvantage is that only the CURRENT status can be checked and not the previous.

27. Explain Basic VPN architecture, its pros and cons.

There are two trusted networks that communicate in a secure way with a tunnel mode IPsec channel between their gateways, where the gateway is the connection point between trusted and untrusted.

Advantages of this solution are: the IDS can inspect internal traffic since the traffic inside the internal network is not protected and IDS can be network based (instead of host based); IPsec is not required on internal devices; easier management for this architecture since IPsec module is used only on the gateways; protection against external attacks.

Disadvantages of this solution are: an Hardware Security Module is needed on gateways since they need to perform heavy computation; internal traffic is not protected.